

EDR Bypass

Here's your **attack described in the same *Cyber Kill Chain* format** you showed — **for the Unit 42 "EDR Bypass Extortion Attempt"** report (not about ManageEngine). I've broken it down into stages with **What, How, and Why** in simple, clear English, based entirely on the actual Unit 42 incident response details. ([Unit 42](#))

1 – Reconnaissance (Scout the Environment)

1. The Purchase (What & How)

- **What they did:** The attacker **bought access** to the victim's network from an initial access broker.
 - **How they did it:** They obtained credentials or a foothold via a legitimate **remote monitoring & management (RMM) tool**, specifically *Atera*, which had already been implanted by another party.
 - **Why:** They didn't have to hunt for a vulnerability — they bought a *door already pried open*. This is faster and lowers risk. ([Unit 42](#))
-

2. Target Selection (What & How)

- **What they did:** The threat actor decided to *target endpoint security protections (AV/EDR)* on the victim's systems.
 - **How they did it:** They identified that the victim was using **Cortex XDR agents** (endpoint defense software).
 - **Why:** They believed that bypassing these protections would allow them unfettered visibility and control for later stages. ([Unit 42](#))
-

3. Toolkit Research (What & How)

- **What they did:** The attacker researched and acquired specialized bypass tooling in underground forums.
 - **How they did it:** They located and tested a specific **AV/EDR bypass tool** offered for sale by a user named *KernelMode* on cybercrime forums like XSS & Exploit. ([Unit 42](#))
 - **Why:** They needed a tool that could neutralize or disable EDR hooks and agent protections so their later activity would be undetected. ([Unit 42](#))
-

2 – Initial Access (Getting In and Staying In)

1. Using Existing Credentials (What & How)

- **What they did:** They used the purchased access to **log into and move within the victim's environment**.
 - **How they did it:** Authentication was achieved via the compromised RMM tool and credentials already present in the environment.
 - **Why:** This gave them an initial foothold without needing new exploits or social engineering. ([Unit 42](#))
-

2. Testing on Virtual Machines (What & How)

- **What they did:** The attacker set up **virtual machines (VMs)** where Cortex XDR was installed.
 - **How they did it:** They installed EDR agents on VMs they controlled to *test their bypass tool* against real defenses.
 - **Why:** They wanted to make sure their bypass tool actually disabled or evaded Cortex XDR *before using it on the victim's network*. This shows planning, not just improvisation. ([Unit 42](#))
-

3 – Weaponization / Tools (Crafting the Arsenal)

1. Bypass Tool (“disabler.exe”) (What & How)

- **What it is:** A custom tool named **disabler.exe** that appears to be based on publicly available code like EDRSandBlast.
 - **How it works:** It targets and **removes EDR hooks**, disables kernel-mode protections, and attempts to weaken security agent internals (using drivers like `wnbios.sys` or `WN_64.sys`).
 - **Why:** This is meant to let other tools (like credential stealers) operate without detection. (Unit 42)
-

2. Auxiliary Tools (What & How)

Besides the bypass tool, Unit 42 found on the rogue VM:

- Multiple builds of **Mimikatz** (credential theft)
- **Cobalt Strike** beacons (command and control)
- **Rclone** renamed as vmware.exe (for exfiltration)
- Tools for shellcode, code obfuscation, port scanning, RDP access, etc.
- Lists of compromised hosts & credentials
- Personal info and 2FA keys
- Training and reference material (`ContiTraining.rar`)
- Payment information stored on disk (Unit 42)

These components show a *full attack kit*, not just a bypass tool. (Unit 42)

4 – Delivery & Execution (Delivering the Tools)

1. Testing the Bypass Tool (What & How)

- **What they did:** They executed the bypass tool on VMs where Cortex XDR was installed.
 - **How they did it:** Video recordings showed the bypass tool disabling protections, followed by successful execution of credential theft tools like Mimikatz.
 - **Why:** They wanted to *validate* the bypass and demonstrate it to potential customers and affiliates — this was *both attack testing and marketing*. (Unit 42)
-



5 – Command, Control (C2) Preparation

This stage wasn't described as a traditional remote backdoor, but these artifacts suggest it:

- **Cobalt Strike beacons** were found, indicating planned C2 channels.
- Credentials and compromised hosts lists give pathways for connection later.
- Rclone renamed as "vmware.exe" implies *a covert data transfer mechanism*. (Unit 42)

These all support planned remote control and data movement. (Unit 42)



6 – Lateral Movement

While the attack *did not proceed fully*, Unit 42 observed signs of lateral techniques similar to known playbooks:

- Use of **PsExec** for remote execution
 - **Cobalt Strike** for remote sessions
 - Bypass of endpoint protections for stealth
 - Credential theft to escalate privileges
 - Multiple compromised hosts ready to be used (anvillogic.com)
-



7 – Data Collection & Intent

In the context of this extortion attempt:

- The attacker intended to *exfiltrate data* and *ransom the victim*.
- They used tools like **Rclone** for data transfer, suggesting they planned to move stolen files offsite.
- Extortion emails/claims were likely backed by threats of data leakage. (anvillogic.com)

This is a motive and intent stage, not just technical activity.



8 – Exfiltration & Extortion

In this case:

- The attack appears to have stopped *before full data theft happened*, but the infrastructure was in place for it.
- The attacker claimed to have data and threatened extortion — either by *public leak*, *ransom*, or both.
- Extortioners often exaggerate or use old data to pressure victims. ([Unit 42](#))

Because Unit 42 intervened, the full exfiltration and ransom demand phase was *thwarted*. ([Unit 42](#))



Clean Summary (Exam/Report Ready)

1. **Reconnaissance:** Attacker buys access via compromised Atera RMM credentials and scopes the environment for EDR. ([Unit 42](#))
2. **Initial Access:** They authenticate into the victim's network using existing access. ([Unit 42](#))
3. **Weaponization:** They collect and customize tools, including an AV/EDR bypass (`disabler.exe`) and auxiliary exploitation tools. ([Unit 42](#))

4. **Delivery & Execution:** The bypass tool is executed against security agents in VMs to confirm EDR defeat. ([Unit 42](#))
 5. **C2 Preparation:** Evidence of Cobalt Strike and credential lists indicates plans to control the network. ([Unit 42](#))
 6. **Lateral Movement:** Tools like PsExec and Cobalt Strike indicate planned spread within the environment. (anvillogic.com)
 7. **Data Collection:** Rclone and stolen credentials suggest intent to collect and move data. ([Unit 42](#))
 8. **Exfiltration & Extortion:** Planned or claimed data theft to extort the victim, though actual damage was stopped by Unit 42. ([Unit 42](#))
-

If you want, I can now:

- ✓ Map each step to **MITRE ATT&CK techniques**
- ✓ Show **defender detection points** (what logs would look like)
- ✓ Write a **one-page recap** you can use in reports

Just tell me which one you want!

Alright bro — now we're going **full DFIR / blue-team depth**, same **What-How-Why** format, **no ManageEngine**, **only the Unit 42 EDR-bypass extortion case**, and **every file + tool explained properly**.

I'll walk the **entire kill chain**, and **whenever a file/tool appears**, I'll stop and explain:

- **What exactly it is**
- **Why attackers chose it**
- **How it works conceptually**
- **What role it plays in THIS attack**

No shortcuts. No fluff. Let's go.

CYBER KILL CHAIN — EDR BYPASS EXTORTION ATTEMPT (UNIT 42)

1. RECONNAISSANCE — *Understanding the Battlefield*

1.1 Buying Access (Initial Recon)

What they did

The attacker **did NOT break in themselves**.

They **bought existing access** to a victim network.

How they did it

They obtained access through a **compromised RMM (Remote Monitoring & Management) tool**, specifically:

Tool: Atera RMM

What is Atera?

- Legitimate IT admin software
- Used to:
 - Run commands remotely
 - Install software
 - Manage endpoints
- Trusted by enterprises
- Often allowed through firewalls

Why attackers love it

- Already installed
- Runs with high privileges

- Looks 100% legitimate
- No exploit required

👉 This access usually comes from **Initial Access Brokers (IABs)** who sell RMM footholds.

Why this mattered

The attacker skipped:

- Phishing
- Exploits
- Malware delivery

They started with:

“I already look like IT.”

1.2 Identifying Endpoint Security

What they did

They checked **what EDR/AV product** was protecting endpoints.

How they did it

From their RMM foothold, they enumerated:

- Running services
- Installed security agents

Target Identified: Cortex XDR

Why this mattered

Everything after this point revolves around:

“How do I neutralize Cortex XDR without triggering it?”

This decision **defines the entire attack.**

2. WEAPONIZATION — *Preparing the EDR Kill Tools*

This is the most important part of the incident.

2.1 The Core Weapon: `disabler.exe`

 **File: disabler.exe**

What it is

A **custom EDR bypass executable**, not mass malware.

It is heavily inspired by:

- **EDRSandBlast**
 - **Bring Your Own Vulnerable Driver (BYOVD)** techniques
-

How `disabler.exe` works (deep but simple)

EDR products protect systems by using:

1. **Kernel drivers**
2. **Kernel callbacks**
3. **Hooks into system events**
4. **Protected processes**

`disabler.exe` attacks **those exact mechanisms**.

2.1.1 Vulnerable Driver Abuse (BYOVD)

Driver used

Unit 42 observed drivers such as:

- `wmbios.sys`
- `WN_64.sys`

What these are

- Legitimate but **old / vulnerable drivers**

- Signed by trusted vendors
- Allow unsafe kernel memory access

Why drivers matter

Drivers run in:

| Ring 0 (kernel mode)

Higher than:

- EDR
 - AV
 - User-mode protections
-

How attackers use the driver

1. Load vulnerable driver
2. Use it to:
 - Kill EDR kernel callbacks
 - Disable process protection
 - Remove hooks
3. Unload driver (sometimes)

👉 Result: **EDR goes blind**

2.1.2 Targeting Protected Processes

What is a protected process?

Windows allows security software to mark itself as:

- **Protected Process Light (PPL)**

This prevents:

- Termination

- Memory access
- Injection

What `disabler.exe` does

Using kernel access, it:

- Removes protection flags
- Allows termination or tampering
- Disables EDR self-defense

Think:

“It turns off the alarm system from inside the walls.”

2.1.3 Kernel Callbacks & Hooks (Why EDR dies)

EDRs rely on:

- Process creation callbacks
- File operation callbacks
- Registry callbacks

`disabler.exe`:

- Enumerates callbacks
- Removes or overwrites them

👉 After this:

- Malware runs
 - No alerts
 - No blocking
 - No logging
-

3. TESTING PHASE — *Before Touching the Victim*

What they did

They **tested everything on their own VMs** first.

How they did it

They:

- Installed **Cortex XDR** on test VMs
- Ran `disabler.exe`
- Recorded videos showing:
 - EDR disabled
 - Mimikatz executing successfully

Why this mattered

This shows:

- Professional planning
- No “trial on victim”
- Reduced detection risk

Also:

- Used as **marketing material** for selling the tool

4. PAYLOAD STAGING — *What Comes After EDR Is Down*

Once EDR is disabled, the attacker prepares **real attack tools**.

4.1 Credential Theft Tool

 **Tool: Mimikatz**

What it is

Credential extraction tool.

Why it needs EDR disabled

- LSASS access triggers EDR alerts
- Dumping memory is noisy

With EDR blind:

- LSASS dumping succeeds
 - No alert fires
-

4.2 Command & Control



Tool: Cobalt Strike

What it is

Red-team / attacker framework.

Used for:

- Beaconing
- Remote command execution
- Lateral movement

Why used here

Once credentials are stolen:

- Cobalt Strike gives full control
 - Memory-resident
 - Highly flexible
-

4.3 Data Exfiltration Prep



Tool: Rclone (renamed)

Observed as:

- `vmware.exe`

What Rclone is

Legitimate cloud sync tool.

Supports:

- Google Drive
- Mega
- S3
- Custom servers

Why attackers use it

- Trusted binary
- Encrypted transfers
- Huge data movement
- Easy to rename

👉 Perfect for extortion theft.

5. EXECUTION — *Turning Access into Power*

What they attempted

After EDR bypass:

1. Dump credentials
2. Deploy C2
3. Prepare extortion

Why this failed

Unit 42 intervened **before full execution**.

But all tooling was **ready**.

6. COMMAND & CONTROL — *How They Would Stay*

Intended C2 Stack

Tool	Purpose
Cobalt Strike	Interactive control
RMM (Atera)	Legitimate persistence
Rclone	Data exfiltration

This combination:

- Avoids malware signatures
- Uses admin-like behavior
- Blends into normal IT traffic

7. EXTORTION INTENT — *Final Goal*

What they planned

Classic **double extortion**:

1. Steal data
2. Threaten leak
3. Demand payment

Evidence

- Rclone staged
- Credential harvesting tools
- Host lists
- Data handling scripts

FINAL CLEAN ATTACK STORY (ONE FLOW)

Bought RMM access

↓

Identified Cortex XDR

↓

Built & tested disabler.exe

↓

Used vulnerable drivers to kill EDR kernel hooks

↓

Disabled protected processes

↓

Prepared Mimikatz + Cobalt Strike

↓

Staged Rclone for data theft

↓

Extortion planned

↓

Attack stopped by Unit 42

ONE-LINE MEMORY ANCHOR

This attack wasn't about breaking in — it was about surgically blinding EDR using kernel-level abuse, then calmly preparing extortion with legitimate tools.

If you want next (high-value options):

-  **How defenders detect kernel callback tampering**
-  **Deep dive: Protected Process Light (PPL)**
-  **How EDRs defend themselves internally**
-  **MITRE ATT&CK mapping (perfect for exams / reports)**

Just tell me.